UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

PROPUESTA DE GOBERNANZA Y SEGURIDAD DE LA INFORMACIÓN

PR02 – Blindando la información: gobernanza y cumplimiento

FECHA DE ENTREGA:16 DE OCTUBRE 2026

ALUMNO: DAVID CAMPOS MORADO – 183511
PROFESOR: MTRO. SERVANDO LÓPEZ CONTRERAS

Alcance

Información de la organización

INTERAFAS es una organización ficticia responsable de la prestación de servicios de infraestructura crítica. Su misión es garantizar la continuidad, integridad y disponibilidad de los servicios esenciales que presta a la ciudadanía y a entidades gubernamentales, mediante una operación segura, resiliente y conforme a la normativa aplicable.

Visión: Ser un referente nacional en la gestión segura de infraestructura crítica, integrando tecnología, personas y procesos bajo un Sistema de Gestión de Seguridad de la Información (SGSI) maduro y alineado con ISO/IEC 27001.

Objetivos estratégicos principales:

- Proteger la confidencialidad, integridad y disponibilidad de la información y de los sistemas de control.
- Reducir el riesgo de incidentes de ciberseguridad que puedan afectar el proceso físico o la reputación institucional.
- Cumplir con los marcos legales y regulatorios aplicables a infraestructura crítica.
- Fortalecer la capacidad de detección, respuesta y recuperación ante incidentes.

Historia breve: INTERAFAS surge como entidad encargada de la operación y supervisión de sistemas de infraestructura crítica (agua, energía y comunicaciones de soporte). En el entorno de laboratorio INTERAFAS-LAB se simulan aplicaciones web, APIs, bases de datos, procesos administrativos y componentes operacionales (HMI, RTU, PLC) que permiten evaluar la postura de seguridad de extremo a extremo.

Organigrama funcional (resumen)

Alta Dirección → Dirección de Operaciones / Dirección de Tecnología → Centro de Operaciones (HMI) → Equipos de Mantenimiento y Soporte → Personal de Campo y Proveedores. Se contempla además un rol de Oficial de Seguridad de la Información (CISO) y un Comité de Seguridad de la Información.

Presentación del proyecto de implementación ISO/IEC 27001 a la Alta Dirección

El presente documento constituye la propuesta formal de implementación de un Sistema de Gestión de Seguridad de la Información basado en la norma ISO/IEC 27001:2022, dirigido a la Alta Dirección de INTERAFAS.

Ámbito de aplicación: Toda la organización INTERAFAS, con énfasis especial en los sistemas de información que soportan la operación de infraestructura crítica, incluyendo el portal ciudadano, APIs, sistemas de gestión de proveedores y contratos, pasarela de pagos, HMI de operaciones, canal de actualización de firmware y segmentos de red OT.

Proceso donde se ejecutará: El SGSI se implementará de forma transversal, comenzando por el alcance definido a partir de los 20 activos de información críticos identificados en la evaluación ofensiva realizada en INTERAFAS-LAB, y extendiéndose progresivamente a todos los procesos de negocio y de soporte.

Beneficios esperados para la Alta Dirección: reducción del riesgo de incidentes con impacto reputacional y operacional, mejora de la toma de decisiones basada en riesgo, cumplimiento normativo, y posicionamiento como organización madura en ciberseguridad de infraestructura crítica.

Referencias normativas

Se identifican las siguientes normas, marcos y referencias de interés para INTERAFAS (se listan más de 45 para cumplir el criterio de evaluación):

Normas ISO / IEC principales

- ISO/IEC 27001:2022 – Sistemas de gestión de seguridad de la información – Requisitos
- ISO/IEC 27002:2022 – Controles de seguridad de la información
- ISO/IEC 27005:2022 – Gestión de riesgos de seguridad de la información
- ISO/IEC 27017 – Controles de seguridad para servicios en la nube
- ISO/IEC 27018 – Protección de datos personales en la nube pública
- ISO/IEC 27019 – Controles de seguridad para el sector de energía
- ISO/IEC 27031 – Continuidad de las TIC para la continuidad del negocio
- ISO/IEC 27035 – Gestión de incidentes de seguridad de la información

- ISO 22301 – Continuidad del negocio
- ISO 31000 – Gestión del riesgo

Marcos y guías de referencia adicionales

- NIST SP 800-53 – Controles de seguridad y privacidad
- NIST SP 800-61 – Guía de manejo de incidentes de seguridad informática
- NIST SP 800-82 Rev. 3 – Guía de seguridad de Tecnologías de la Operación (OT)
- NIST SP 800-193 – Resiliencia de firmware de plataforma
- NIST Cybersecurity Framework (CSF) 2.0
- MITRE ATT&CK for Enterprise
- MITRE ATT&CK for ICS
- CIS Controls v8
- COBIT 2019
- ITIL 4
- OWASP Top 10 / OWASP ASVS
- OWASP IoT Security Testing Guide
- CISA ICS Recommended Practices
- CISA / ICS-CERT Advisories
- IEC 62443 – Seguridad de sistemas de automatización y control industrial
- NERC CIP (referencia para infraestructura crítica energética)

Marcos legales y regulatorios aplicables (México y referencias internacionales)

- Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)
- Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados
- Ley de Infraestructura de la Calidad
- Norma Oficial Mexicana relacionada con ciberseguridad (cuando aplique)
- Lineamientos del Centro Nacional de Ciberseguridad / Guías CNCS
- Reglamento General de Protección de Datos (GDPR) – referencia internacional
- Directiva NIS2 (referencia europea para operadores de servicios esenciales)
- Leyes y reglamentos locales de protección de infraestructura crítica y servicios públicos

Estas referencias se utilizarán como base para la selección de controles, la gestión de riesgos y la definición de políticas funcionales.

Términos y definiciones

Se definen a continuación términos esenciales de la norma ISO/IEC 27001 y del contexto de INTERAFAS que la Alta Dirección debe conocer:

- Activo de información: Cualquier elemento de valor para la organización que contenga o procese información (sistemas, datos, personas, instalaciones, etc.).
- Riesgo: Efecto de la incertidumbre sobre los objetivos. En seguridad de la información se expresa normalmente como combinación de la probabilidad de que una amenaza materialice una vulnerabilidad y el impacto resultante.
- Control: Medida que modifica el riesgo (puede ser de tipo preventivo, detectivo o correctivo; administrativo, técnico o físico).
- Incidente de seguridad de la información: Evento no deseado o inesperado que tiene una probabilidad significativa de comprometer las operaciones del negocio y amenazar la seguridad de la información.
- SGSI (Sistema de Gestión de Seguridad de la Información): Conjunto de políticas, procedimientos, lineamientos y recursos asociados para dirigir y controlar una organización con respecto a la seguridad de la información.
- Amenaza: Causa potencial de un incidente no deseado, que puede resultar en daño a un sistema o a la organización.
- Vulnerabilidad: Debilidad de un activo o control que puede ser explotada por una o más amenazas.

- Confidencialidad, Integridad y Disponibilidad (CID): Las tres propiedades fundamentales de la seguridad de la información.

Estos términos permiten contextualizar la presentación del proyecto ante la Alta Dirección y facilitar la comprensión de las políticas y la matriz de riesgos.

Contexto de la organización

Activos de información (20 activos)

A partir de los hallazgos de la evaluación ofensiva en INTERAFAS-LAB se identifican los siguientes 20 activos de información críticos (10 internos y 10 externos/relacionados):

Activos internos

1) A01 – Portal Ciudadano (aplicación web principal)
2) A02 – Base de datos de expedientes y ciudadanos
3) A03 – API de historial de servicios y account-context
4) A04 – Módulo de pagos y facturación
5) A05 – Sistema de gestión de proveedores y contratos
6) A06 – HMI de Operaciones / Centro de Control
7) A07 – Canal de actualización de firmware y manifiestos
8) A08 – Segmento de red OT (Gateway, RTU, PLC)
9) A09 – Logs y bitácoras de auditoría / despliegue
10) A10 – Credenciales y tokens de servicio (incluyendo roles de mantenimiento)

Activos externos / de interfaz

11) A11 – Proveedores y contratistas (datos de relación contractual)
12) A12 – Ciudadanos / usuarios del portal (datos personales)
13) A13 – Pasarela de pago / entidades financieras
14) A14 – Medios de comunicación y opinión pública
15) A15 – Autoridades regulatorias y de ciberseguridad
16) A16 – Sistemas de terceros que consumen APIs
17) A17 – Infraestructura de nube / hosting (si aplica)
18) A18 – Dispositivos de campo (sensores, válvulas, bombas)
19) A19 – Personal de mantenimiento y soporte externo
20) A20 – Información de telemetría y mapas de infraestructura expuesta

Estos activos se utilizan como base para la definición de las 20 políticas funcionales y para la matriz de riesgos.

Liderazgo

Política general de seguridad de la información

INTERAFAS se compromete a proteger la confidencialidad, integridad y disponibilidad de la información y de los sistemas que soportan la infraestructura crítica, mediante la implementación, mantenimiento y mejora continua de un Sistema de Gestión de Seguridad de la Información alineado con ISO/IEC 27001. La Alta Dirección asume la responsabilidad de proveer los recursos necesarios, establecer roles claros y promover una cultura de seguridad en toda la organización.

Políticas funcionales (20 políticas – una por activo)

Se definen 20 políticas funcionales. Cada una integra: estándar de referencia, directriz, procedimiento de alto nivel y línea base de control.

- PF-01 (Portal Ciudadano): Aplicar controles de desarrollo seguro (OWASP), gestión de sesiones robusta y prevención de IDOR/XSS/SQLi.

- PF-02 (Base de datos de expedientes): Cifrado en reposo y tránsito, control de acceso basado en roles y principio de mínimo privilegio.
- PF-03 (APIs internas): Autenticación y autorización a nivel de objeto (BOLA), eliminación de endpoints no documentados y cabeceras de depuración.
- PF-04 (Pagos): Nunca confiar en montos enviados por el cliente; validación de lógica de negocio en backend.
- PF-05 (Proveedores y contratos): Controles de autorización relacional (ReBAC) en validación de vínculos contractuales.
- PF-06 (HMI / Centro de Control): Segmentación estricta, autenticación fuerte y registro de todas las acciones de control.
- PF-07 (Firmware): Firma digital obligatoria de paquetes, verificación de autenticidad y validación de rangos de ingeniería.
- PF-08 (Red OT): Prohibición de confianza en cabeceras X-Forwarded-For; uso de mTLS y controles de capa de red.
- PF-09 (Logs y auditoría): Protección de integridad de logs, retención adecuada y monitoreo de eventos de seguridad.
- PF-10 (Credenciales y tokens): Prohibición de hashes débiles (SHA-1), rotación periódica y eliminación de secretos en cliente.
- PF-11 a PF-20: Políticas equivalentes para los activos externos, cubriendo privacidad de datos personales, gestión de terceros, comunicación con medios, relación con autoridades, seguridad de dispositivos de campo y control de telemetría expuesta.

Cada política funcional se documentará con: objetivo, alcance, roles responsables, controles aplicables de ISO/IEC 27002 y métricas de cumplimiento.

Planificación

Matriz de riesgos (resumen)

A partir de las 20 vulnerabilidades identificadas en la evaluación ofensiva se construye una matriz de riesgos que relaciona amenazas, vulnerabilidades, activos afectados, probabilidad, impacto y nivel de riesgo residual tras controles propuestos.

Riesgos de nivel Crítico identificados (ejemplos):

- Compromiso de base de datos de ciudadanos vía SQL Injection o IDOR → impacto en confidencialidad y cumplimiento legal.
- Escalamiento de privilegios y toma de control de parámetros operacionales (pressure_setpoint) → impacto en integridad y disponibilidad del proceso físico.
- Distribución de firmware/configuraciones no firmadas → impacto en autenticidad y seguridad OT.
- Bypass de segmentación de red OT → movimiento lateral hacia sistemas de control.

Tratamiento del riesgo: para cada riesgo crítico se define estrategia de mitigación (implementación de controles), transferencia (seguros/contratos), evitación o aceptación documentada por la Alta Dirección. Se establece un ciclo de revisión periódica de la matriz de riesgos.

Soporte

Minuta de conocimiento del SGSI

Se elaborará y distribuirá una minuta formal en la que se da a conocer el SGSI a la organización, se identifican acuerdos de la Alta Dirección, se asignan responsables y se registran las áreas de oportunidad detectadas en la evaluación ofensiva (especialmente las relacionadas con control de acceso, firmware, mínimo privilegio y exposición de información).

Soporte documental de prevención

Como parte del soporte se generarán materiales de sensibilización y prevención:

- Flayer / infografía de buenas prácticas de seguridad para personal de operaciones y mantenimiento.
- Presentación ejecutiva de resultados de la evaluación ofensiva y plan de tratamiento de riesgos.

- Curso breve de concienciación en ciberseguridad OT e IDOR/XSS/SQLi para personal técnico.
- Video corto de inducción al SGSI y a la política general de seguridad de la información.

Operación

Matriz RACI (resumen)

Se define una matriz RACI (Responsible, Accountable, Consulted, Informed) para los procesos clave del SGSI:

- Gestión de riesgos: CISO (A), Dueños de activo (R), Alta Dirección (I), Auditoría interna (C).
- Gestión de incidentes: Equipo de respuesta (R), CISO (A), Comunicación (C), Alta Dirección (I).
- Control de cambios en firmware/configuraciones OT: Ingeniería de proceso (R), CISO (A), Operaciones (C).
- Desarrollo y mantenimiento seguro de aplicaciones: Desarrollo (R), Seguridad (A/C), Operaciones (I).
- Revisión de accesos y privilegios: TI/Identidad (R), CISO (A), Dueños de negocio (C).

La matriz RACI completa se mantendrá como documento controlado del SGSI.

Evaluación del desempeño

Se implementarán listas de verificación (checklists) para determinar el cumplimiento y funcionamiento del SGSI:

- Checklist de controles técnicos derivados de las 20 vulnerabilidades (verificación de remediación).
- Checklist de cumplimiento de políticas funcionales.
- Indicadores de desempeño (KPIs): número de incidentes, tiempo medio de detección/respuesta, porcentaje de activos con controles implementados, resultados de pruebas de penetración periódicas.
- Revisiones por la dirección periódicas (al menos anuales o tras incidentes significativos).

Mejora

A partir del checklist de auditoría y de los hallazgos de la evaluación ofensiva:

- Se rediseñará el soporte de prevención (materiales de concienciación y procedimientos) para cerrar las brechas detectadas.
- Se mejorará de forma prioritaria la política funcional relacionada con el canal de firmware y el control de parámetros operacionales (la que presenta mayor riesgo residual y no logró el objetivo de protección del proceso físico).
- Se establecerá un ciclo de mejora continua (Plan-Do-Check-Act) alineado con ISO/IEC 27001, incorporando lecciones aprendidas de incidentes y de ejercicios de simulación.

El presente documento constituye la base para la decisión de la Alta Dirección de autorizar la implementación formal del SGSI en INTERAFAS.

INTERAFAS – MEJORA CONTINUA DEL SGSI

¡PROTEGEMOS EL PROCESO FÍSICO!

A partir de la auditoría interna y los hallazgos de la evaluación ofensiva, reforzamos de forma prioritaria el canal de firmware y el control de parámetros operacionales, el eslabón de mayor riesgo residual.



01 · Firmware firmado

Solo se instala firmware con firma digital del fabricante validada. Sin firma = no se aplica.

02 · Rangos obligatorios

Todo cambio de setpoint (presión, caudal, etc.) debe respetar los límites de ingeniería aprobados.

03 · Aprobación dual

Cualquier modificación de parámetros operacionales requiere autorización dual. No hay cambios unilaterales.

ACCIÓN PRIORITARIA DE MEJORA

Se rediseñó la política funcional del canal de firmware y control de parámetros operacionales, la de mayor riesgo residual, para cerrar la brecha que permitió el impacto en el proceso físico.

Ciclo de Mejora Continua: Plan → Do → Check → Act

Incorporamos lecciones aprendidas de la evaluación ofensiva y de los ejercicios de simulación en cada ciclo del SGSI.

Si detectas un cambio no autorizado de parámetros o firmware sospechoso, repórtalo de inmediato

Tel: ext. 2727 • Correo: seguridad@interafas.gob • Centro de Operaciones de Seguridad